

Recommendations

Based on the assessment, Botium Toys should prioritize implementing and strengthening security controls according to the NIST Cybersecurity Framework (CSF) to reduce organizational risk and improve compliance.

Identify

Improve Asset Inventory and Classification

The IT department should maintain an up-to-date inventory of all hardware, software, network devices, and sensitive data assets. Assets should also be classified according to their criticality and business value so that security controls can be prioritized appropriately and potential risks can be assessed more effectively.

Protect

Implement the Principle of Least Privilege

Employees should only have access to the systems, applications, and data required to perform their job responsibilities. Access permissions should be reviewed periodically to ensure they remain appropriate as employees change roles or leave the organization.

Implement Separation of Duties

Critical tasks should require multiple individuals or approval steps to reduce the risk of fraud, human error, or abuse of privileged accounts. For example, employees responsible for processing financial transactions should not also be able to approve or audit those same transactions.

Strengthen Access Control Policies

Role-based access control (RBAC) should be implemented to ensure that users can only access information appropriate to their job functions. Regular access reviews should be conducted to remove unnecessary or outdated permissions.

Encrypt Sensitive Data

Customer payment information and other sensitive data should be encrypted both while stored (data at rest) and while transmitted across networks (data in transit). Encryption helps maintain confidentiality even if unauthorized access occurs.

Deploy a Centralized Password Management System

A centralized password management solution should enforce password policies, securely store credentials, simplify password resets, and reduce the risk associated with weak or reused passwords.

Strengthen the Existing Password Policy

The existing password policy should be updated to require stronger passwords, including minimum length, uppercase and lowercase letters, numbers, and special characters. Multi-factor authentication (MFA) should also be implemented for accounts that access sensitive systems.

Establish a Formal Maintenance Schedule for Legacy Systems

Legacy systems should continue to be monitored, but maintenance activities should follow a documented schedule with clearly assigned responsibilities. Regular updates, vulnerability assessments, and system reviews will reduce the risk posed by unsupported or aging technology.

Detect

Deploy an Intrusion Detection System (IDS)

An IDS should be installed to continuously monitor network traffic and generate alerts whenever suspicious or malicious activity is detected. This will enable the IT department to identify potential security incidents more quickly and respond before they escalate.

Respond & Recover

Implement Regular Backups

Critical business data should be backed up automatically on a regular schedule. Backup copies should be securely stored and periodically tested to ensure they can be successfully restored when needed.

Develop and Test a Disaster Recovery Plan

A formal disaster recovery plan should define procedures for restoring systems, recovering data, assigning responsibilities, and maintaining business continuity after a cyberattack, hardware failure, or natural disaster. The plan should be tested regularly to ensure its effectiveness.

Conclusion

Implementing these recommendations will significantly strengthen Botium Toys' security posture by improving asset management, reducing unauthorized access, enhancing threat detection capabilities, and increasing organizational resilience. These improvements will also help the organization better align with industry best practices and compliance requirements such as PCI DSS, GDPR, and SOC.